S06 Scanning

Network, Port and Vulnerability Scanning — Metasploitable 2

Raja Wardet Wahaj

Cohort2: DFCS Bootcamp — Atomcamp

Repository path: https://github.com/WardetWahaj/pseb-dfcs-bootcamp

Tasks completed: Task A (three findings), B3, B4

Environment: Kali Linux attacker (192.168.50.x) / Metasploitable 2 target (192.168.37.132), NAT lab

Task A — Three Complete Findings

Each finding below follows the report template: title, severity, affected asset, identifiers, description, evidence, proof of concept, impact, remediation and references.

Finding 1 — FTP Backdoor Command Execution in vsftpd 2.3.4

Severity	9.8 Critical — CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Affected asset	192.168.37.132:21/tcp, vsftpd 2.3.4
Identifiers	CVE-2011-2523 [1] · CWE-78 [2] · cpe:/a:vsftpd:vsftpd:2.3.4
Description	The vsftpd 2.3.4 archive distributed between 30 June and 3 July 2011 contained a backdoor. A username containing a specific character sequence opens a shell listener on 6200/tcp. The backdoor was added to the download server's archive, not to the upstream source — a supply-chain compromise rather than a coding error [1][3].

Evidence

```
nmap -sV -p21 192.168.37.132
nmap -p21 --script ftp-vsftpd-backdoor.nse 192.168.37.132
```



Proof of concept

1. Connect to TCP 21 and supply the triggering username sequence. 2. Confirm 6200/tcp opened: nmap -p6200 192.168.37.132. 3. Connect to 6200 and run id; the reply shows the privilege level of the shell.

Impact	Unauthenticated remote code execution as the FTP service account, on a host that also serves MySQL (3306) and PostgreSQL (5432), exposing database content.
Remediation	Upgrade vsftpd to a current release from the distribution repository and verify package signatures. Treat any host that ran the compromised archive as compromised, since patching alone does not remove a backdoor introduced via the archive.
References	[1][2][3] — see References section

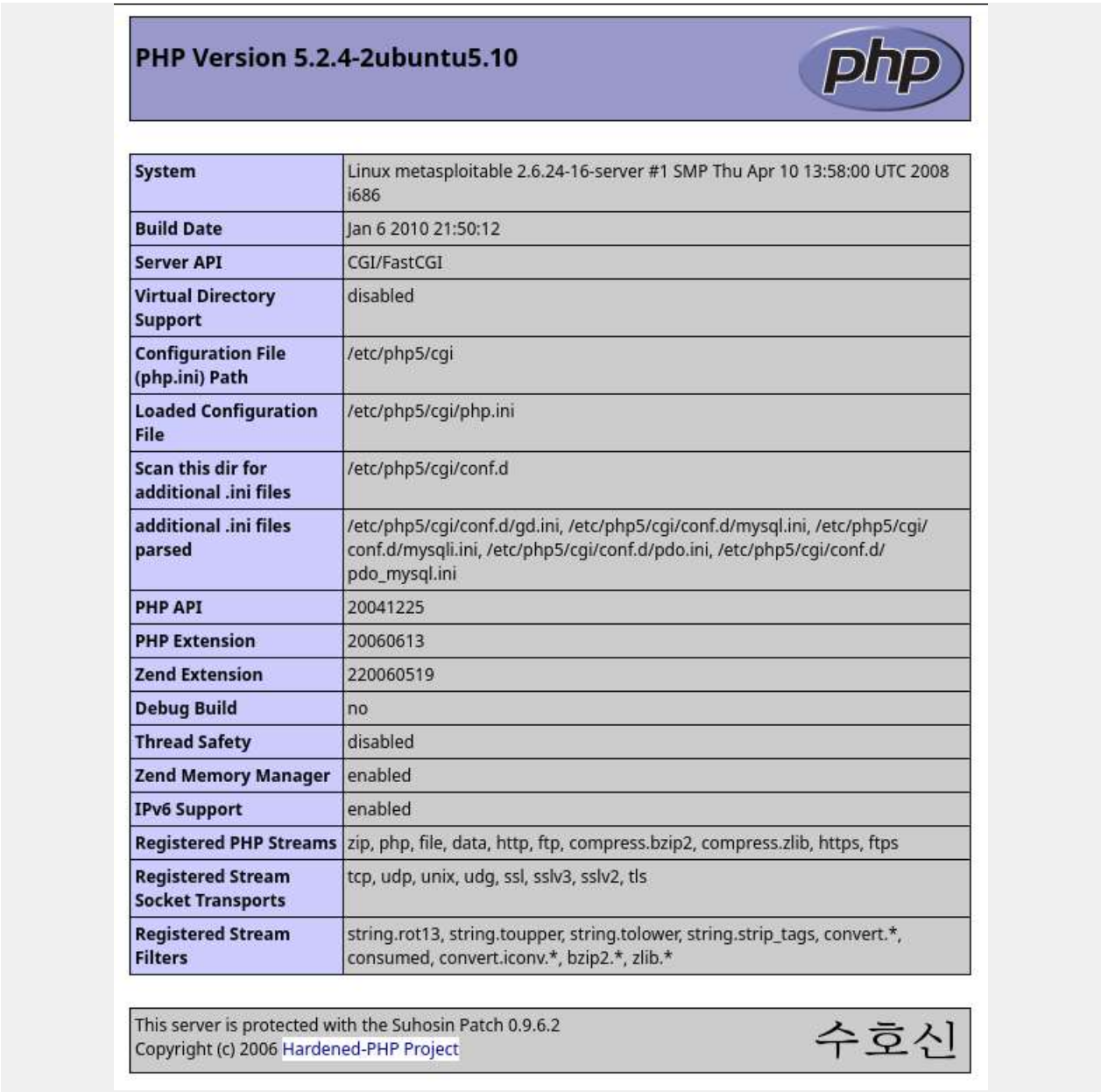
Finding 2 — Exposed phpinfo.php (Information Disclosure)

Severity	5.3 Medium — CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Affected asset	192.168.37.132:80/tcp, Apache httpd 2.2.8, /phpinfo.php
Identifiers	CWE-200 [4] — no CVE; this is a configuration weakness, not a product bug
Description	A diagnostic page printing the PHP version, loaded modules, configuration values, environment variables and server paths is reachable without authentication.

Evidence

```
nmap -p80,8180 --script http-enum.nse 192.168.37.132
```





PHP Version 5.2.4-2ubuntu5.10

System	Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686
Build Date	Jan 6 2010 21:50:12
Server API	CGI/FastCGI
Virtual Directory Support	disabled
Configuration File (php.ini) Path	/etc/php5/cgi
Loaded Configuration File	/etc/php5/cgi/php.ini
Scan this dir for additional .ini files	/etc/php5/cgi/conf.d
additional .ini files parsed	/etc/php5/cgi/conf.d/gd.ini, /etc/php5/cgi/conf.d/mysql.ini, /etc/php5/cgi/conf.d/mysqli.ini, /etc/php5/cgi/conf.d/pdo.ini, /etc/php5/cgi/conf.d/pdo_mysql.ini
PHP API	20041225
PHP Extension	20060613
Zend Extension	220060519
Debug Build	no
Thread Safety	disabled
Zend Memory Manager	enabled
IPv6 Support	enabled
Registered PHP Streams	zip, php, file, data, http, ftp, compress.bzip2, compress.zlib, https, ftps
Registered Stream Socket Transports	tcp, udp, unix, udg, ssl, sslv3, sslv2, tls
Registered Stream Filters	string.rot13, string.toupper, string.tolower, string.strip_tags, convert.*, consumed, convert.iconv.*, bzip2.*, zlib.*

This server is protected with the Suhosin Patch 0.9.6.2
Copyright (c) 2006 Hardened-PHP Project

Proof of concept

1. Run the http-enum scan above. 2. Request http://192.168.37.132/phpinfo.php in a browser. 3. Record the PHP version and document root shown on the page. No exploitation needed.

Impact	An anonymous visitor learns exact software versions and file paths, shortening the research step for later version-to-CVE attacks. Nothing is modified.
Remediation	Delete phpinfo.php from the web root. Restrict diagnostic pages to administrators or a management network. Review the web root for other leftover files.
References	[4] — see References section

Finding 3 — Telnet Service Exposed (Weak Protocol)

Severity	5.9 Medium — CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N
Affected asset	192.168.37.132:23/tcp, telnet

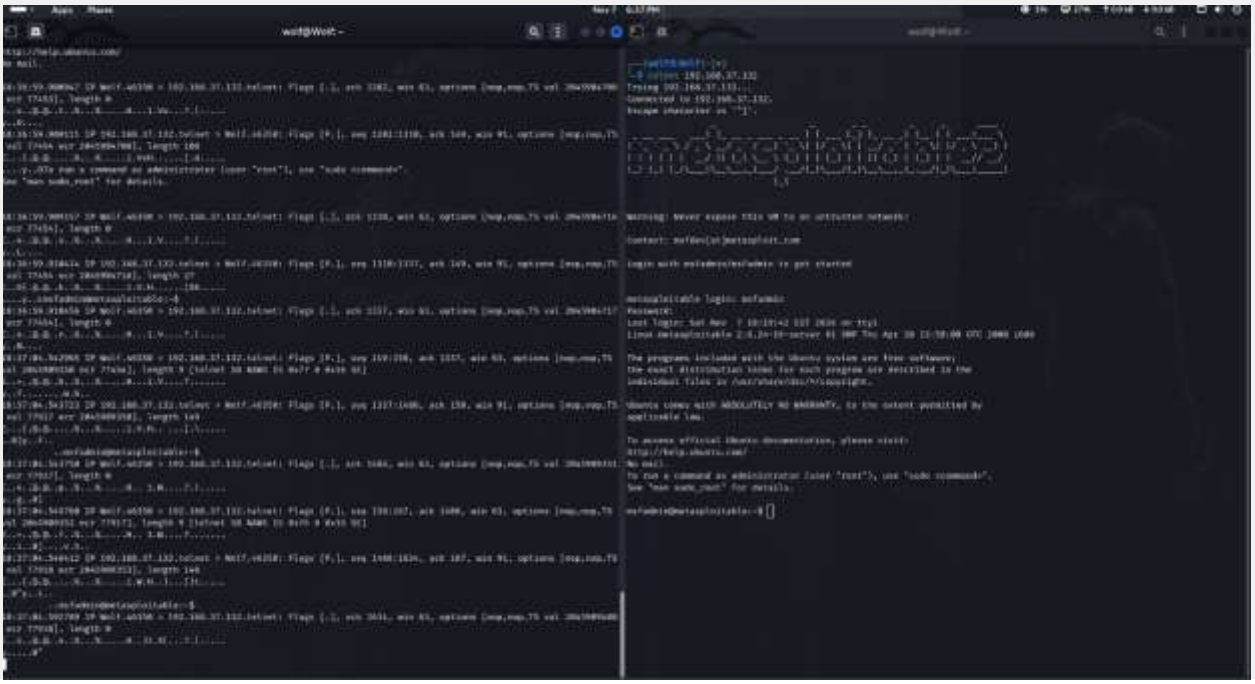
Identifiers	CWE-319 [5] — Cleartext Transmission of Sensitive Information
Description	Telnet sends usernames, passwords and the whole session in cleartext — a design-level weakness of the protocol, not a bug in one version.

Evidence

```
nmap 192.168.37.132   # confirms 23/tcp open telnet
```

```
┌──(wolf㉿Wolf)-[~]
└─$ nmap $TARGET
Starting Nmap 7.991 ( https://nmap.org ) at 2026-11-07 18:29 -0500
Nmap scan report for 192.168.37.132 (192.168.37.132)
Host is up (0.0021s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE
21/tcp   open  ftp
22/tcp   open  ssh
23/tcp   open  telnet
25/tcp   open  smtp
53/tcp   open  domain
80/tcp   open  http
111/tcp  open  rpcbind
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
512/tcp  open  exec
513/tcp  open  login
514/tcp  open  shell
1099/tcp open  rmiregistry
1524/tcp open  ingreslock
2049/tcp open  nfs
2121/tcp open  ccproxy-ftp
3306/tcp open  mysql
5432/tcp open  postgresql
5900/tcp open  vnc
6000/tcp open  X11
6667/tcp open  irc
8009/tcp open  ajp13
8180/tcp open  unknown
MAC Address: 00:0C:29:FA:DD:2A (VMware)

Nmap done: 1 IP address (1 host up) scanned in 0.29 seconds
```



Proof of concept

1. Start a capture on Kali: sudo tcpdump -i eth0 -A port 23. 2. In a second terminal, telnet 192.168.37.132 and log in with a lab account. 3. Credentials appear readable in the capture. Lab only.

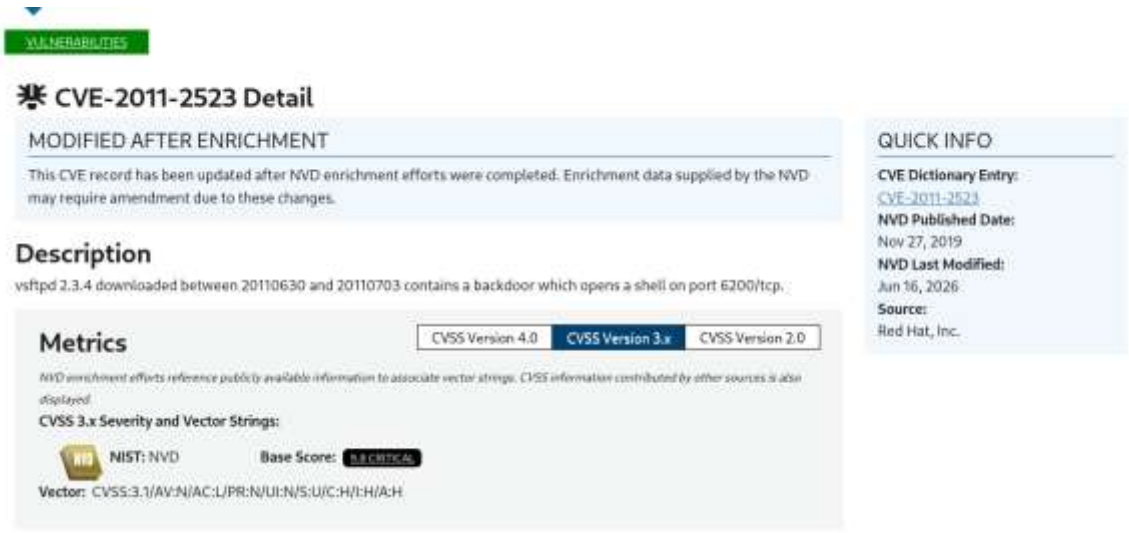
Impact	Anyone positioned on the network path can read login credentials and the whole session. Attack Complexity is rated High because the attacker must first be on-path.
Remediation	Disable telnet and use SSH (22/tcp, already running). Block 23/tcp at the firewall.
References	[5] — see References section

Task B3 — CVSS Vector for CVE-2011-2523, Decoded

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H = 9.8 Critical

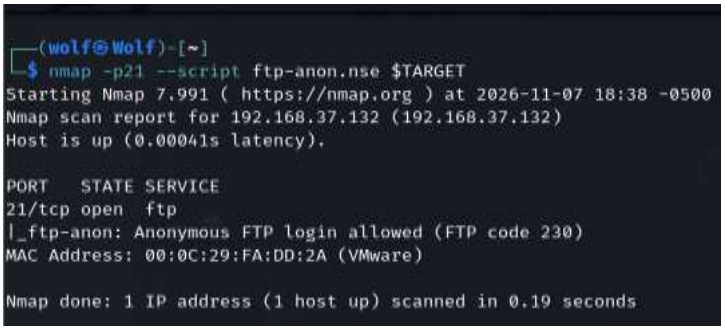
Metric	Value	Plain English
Attack Vector	Network	The attacker can be anywhere that can reach the port
Attack Complexity	Low	No special conditions; works every time
Privileges Required	None	No account is needed
User Interaction	None	No employee has to click or approve anything
Scope	Unchanged	Damage stays inside the vulnerable component's own boundary
Confidentiality	High	Everything the compromised account can read is exposed
Integrity	High	Everything it can write can be altered
Availability	High	The attacker can stop the service or take the host offline

One-sentence summary for a manager: an anonymous attacker anywhere on the network can take full control of this server with one connection, no password and no help from any employee.



Task B4 — CWE Classification for Three Vulnerabilities

#	Vulnerability	CWE	Reasoning
1	vsftpd 2.3.4 backdoor (CVE-2011-2523)	CWE-78 [2] OS Command Injection	Input (the triggering username) reaches a system shell.
2	Anonymous FTP login allowed	CWE-306 [6] Missing Authentication for Critical Function	The service grants file access with no identity check at all.
3	Telnet in use (port 23)	CWE-319 [5] Cleartext Transmission	Credentials cross the network unencrypted.



How remediation differs by class

CWE-78 (injection / malicious code): fixing the one binary is not enough. Replace the software from a trusted source, verify signatures, and treat the host as compromised. For your own code, search for the same pattern (untrusted input reaching a shell) everywhere.

CWE-306 (missing authentication): a configuration change. Disable anonymous access or require credentials, then re-test with ftp-anon. No software upgrade is needed.

CWE-319 (cleartext protocol): a design replacement. Retire the protocol and move to an encrypted equivalent (SSH). Patching telnet cannot fix it.

Each class needs a different owner and a different type of fix, which is why the report carries the CWE and not only the CVE.

GitHub Repository Structure

```
s06-scanning/
├── README.md
├── day2-homework.md  (or this .docx)
└── figures/
    ├── f1-nmap-vsftpd-version.png
    ├── f1-nmap-backdoor-script.png
    ├── f2-http-enum.png
    ├── f2-phpinfo-browser.png
    ├── f3-nmap-telnet-open.png
    ├── f3-tcpdump-capture.png
    └── b4-ftp-anon.png
```

References

1. Debian Security Tracker, CVE-2011-2523. https://security-tracker.debian.org/tracker/CVE-2011-2523

2. MITRE, CWE-78: Improper Neutralization of Special Elements used in an OS Command. https://cwe.mitre.org/data/definitions/78.html

3. Openwall oss-security mailing list, vsftpd-2.3.4 backdoor disclosure (11 July 2011). https://www.openwall.com/lists/oss-security/2011/07/04/4

4. MITRE, CWE-200: Exposure of Sensitive Information to an Unauthorized Actor. https://cwe.mitre.org/data/definitions/200.html

5. MITRE, CWE-319: Cleartext Transmission of Sensitive Information. https://cwe.mitre.org/data/definitions/319.html

6. MITRE, CWE-306: Missing Authentication for Critical Function. https://cwe.mitre.org/data/definitions/306.html

7. NIST National Vulnerability Database, CVE-2011-2523 record (CVSS v3.1 vector). https://nvd.nist.gov/vuln/detail/CVE-2011-2523